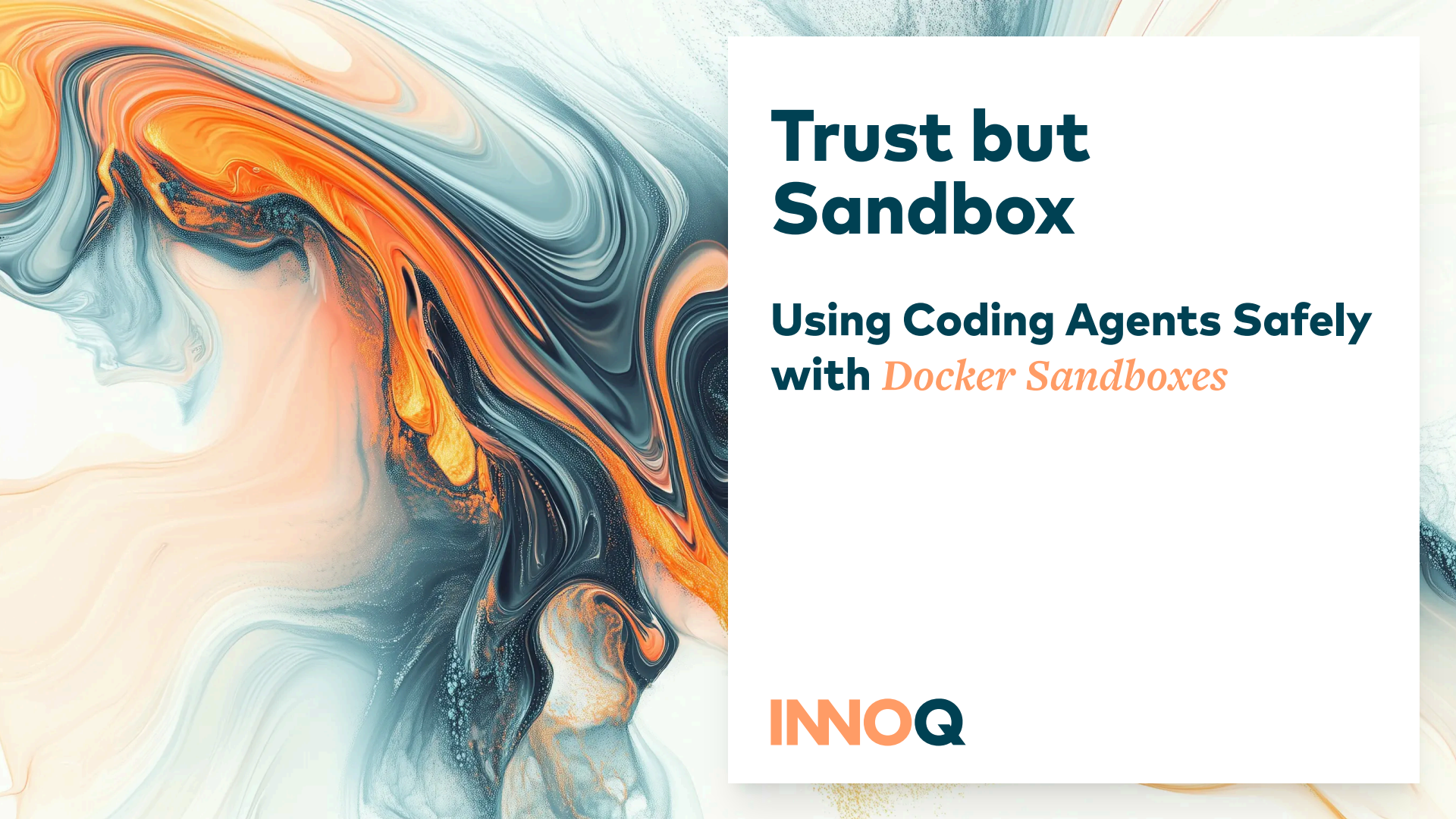




Trust but Sandbox

Using Coding Agents Safely
with *Docker Sandboxes*

INNOQ



Hi



MICHAEL KRÄMER
PRINCIPAL CONSULTANT / METICULATOR

Agents can do *almost* anything.



- Read and write on the **entire disk**
 - not just the project folder
- Execute arbitrary shell commands
- Network access without restrictions
- read your env 🔑 📄
- use your browser with all those 🍪

Behavior is determined *by the model* — and is *barely verifiable*.

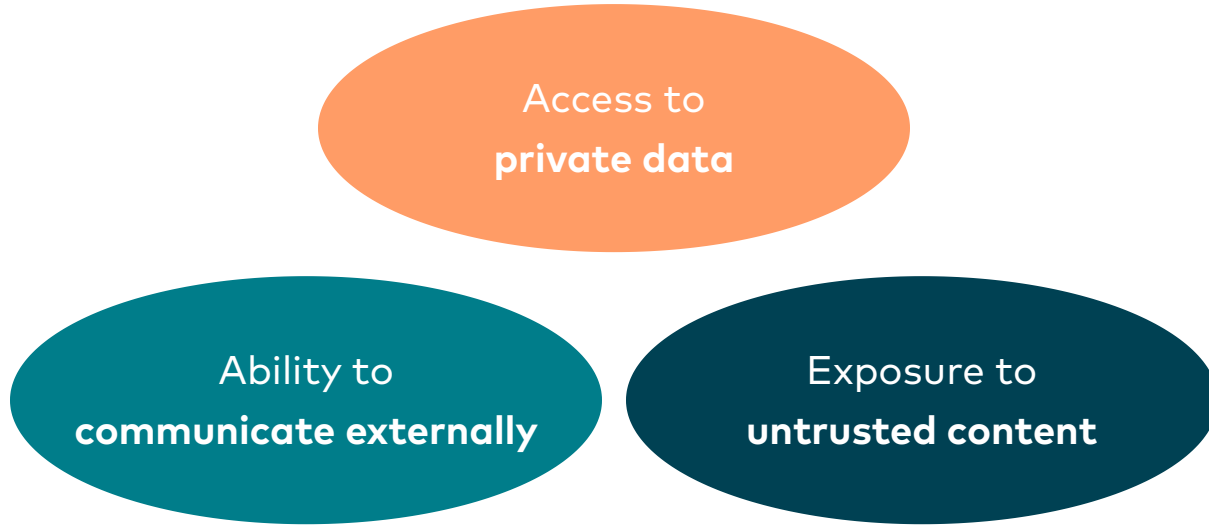
Agents are creative

- Confirmation prompts before tool use wired in client code — not in the model 👍
- Agents find ways around restrictions when it serves the goal ⚠️
- Agentic work requires autonomy for the agent 🚀
- Unstructured input from many sources: not all of them are trustworthy ⚠️⚠️

Prompt injection via MCP servers, APIs, files — not a theoretical risk.

The Risk Triangle

(aka Lethal Trifecta for Agents)*



Two of these aspects are significantly less risk than covering all three.

* A term coined by Simon Willison

Solution:

Docker Sandboxes (sbx)

Docker Sandboxes

- Solution from Docker Inc., based on MicroVM
- No shared kernel, but little overhead
- Lots of conventions for easy use
- Relatively new, fresh out of "Early Access"

What is it?

Where does it help?

AREA	PROTECTION
Filesystem	Only the mounted project directory is accessible
Network	Configurable policies (Open / Balanced / Locked Down)
Credentials	Proxy on host injects tokens — never visible inside the VM
Host system	Completely isolated from the VM

That should *provide enough control* for YOLO mode

--dangerously-skip-permissions is the default in sbx

Live Demo



Pro

- Strong isolation with low overhead
- Credentials never visible to the agent
- Network policies granularly configurable
- ASCII dashboard for overview
- works with many agents

Con

- Still very new, moving target
- Many projects = many VMs
- No file masking in project folder (workaround: symlinks)
- IDE on host / agent in VM: separate network can interfere

But what about

Alternatives?

Alternative: Docker Container

- Shared kernel — weaker isolation than MicroVM
- No dedicated Docker daemon → Docker-in-Docker required for container builds
- Manual setup: no ready-made agent template, no credential proxy

Verdict: feasible, but significantly more effort for less security

Alternative: Claude `--sandbox`

- Agent-side feature, not system-level protection
 - at least it didn't work for me
- Restricts tool use in the agent — but no real isolation
- No protection against prompt injection from external sources
- vendor lock-in

Verdict: useful as a second line of defense, does not replace a system-level sandbox

Alternative: Cloud Sandboxes

GitHub Codespaces, E2B.dev and similar

- Real isolation in the cloud — no local risk
- No access to local resources (filesystem, local services)
- Latency and costs depending on usage

Verdict: great for teams and CI, less practical for local development

Configuration & Customization

- Easy: Agent settings in the project folder for context and constraints
 - .claude / .agent folder, skills, ...
- Network policy overridable per project
- Status bar and agent behavior customizable
- Custom sandboxes based on other images or other agents, like pi
 - <https://github.com/docker/sbx-kits-contrib>

Outlook & Links

- **Kits:** pre-configured sandbox environments
- Git clone mode
- Image pasting (currently doc-only 🤔)
- File masking in project folder (still open)
- VM update automation?
- <https://github.com/restyler/awesome-sandbox>

Agents need freedom. Sandboxes give them that freedom — *without putting your system at risk.*

- sbx run claude — one command, real isolation
- YOLO mode  — but in the VM, not on your laptop
- Still young. Changes, but reliable for everyday use

Docs: docs.docker.com/ai/sandboxes

Thanks for listening! Questions?!



MICHAEL KRÄMER
PRINCIPAL CONSULTANT





For over 25 years, we work in implementing IT systems of all shapes and sizes.

Our expertise is grounded in years of hands-on experience in software development.

We don't see **technology as an end in itself**, but as an **enabler for solving real-world problems**.

www.innoq.com
info.ch@innoq.com
Tel. +41 41 743 01 11

QR

We're here to help

Software Architecture & Consulting: What's the best way forward? Which approach fits best to your goals?

Implementation: Complete or partial implementation of your IT project by one or more interdisciplinary expert teams.

Cloud Native & DevOps: We can shape your solution to run on modern infrastructure - either by you or by us.

Trainings: We offer many ISAQB and other trainings to enable your team.

AI-readiness: Our experts can help modernize your development organization as well as with making your data accessible for AI.